

1. 目的・適用範囲

本規程は、架空企業Example Worksにおける情報資産の取扱いを定めます。
正社員、契約社員、業務委託先を含む、情報資産へアクセスする全利用者に適用します。

2. 情報分類と保管

情報は「公開」「社内限定」「機密」の3区分で管理します。機密情報は暗号化された会社指定ストレージに保存し、アクセス権を四半期ごとに棚卸しします。

機密情報の標準保管期間

7年間

3. セキュリティインシデント対応

不審なメール、端末紛失、誤送信、マルウェア感染を検知した利用者は、端末をネットワークから切り離し、直属の上長とCSIRTへ一次報告します。証拠となるメールやログは削除せず、そのまま保全してください。

CSIRTへの一次報告期限

検知から30分以内

4. 重大度とエスカレーション

個人情報の漏えい、基幹システム停止、ランサムウェアの疑いは重大度Highです。Highの場合、CSIRT責任者は60分以内にCISOへ報告し、対策本部の設置可否を判断します。

5. リモートワーク

社外から業務システムへ接続するときは、会社指定VPNと多要素認証を必ず使用します。公共Wi-Fiへ直接接続して業務データを送受信してはいけません。

端末の自動画面ロック

無操作5分

6. 禁止事項

個人所有のUSBメモリへの保存、個人メールへの転送、未承認の生成AIサービスへの機密情報入力を禁止します。例外が必要な場合は、情報セキュリティ部の事前承認を取得します。